Introduction to Cryptography

Lecture 5: A Model for Network Security

Dr. Siddhant Thapliyal

Department of Computer Science and Engineering
Graphic Era (Deemed to be University), Dehradun

Basic Communication Model

A message is transferred from one party to another through a communication network.



Principals

The sender and recipient are the principal entities participating in the communication.

Establishing a Communication Channel

For communication to take place:

- A route must be established from the sender to the recipient.
- Both parties must use compatible communication protocols.
- The network must transport the message correctly.
- The sender and recipient must cooperate.

Example

TCP/IP protocols create a logical information channel between two communicating systems.

Why is Network Security Required?

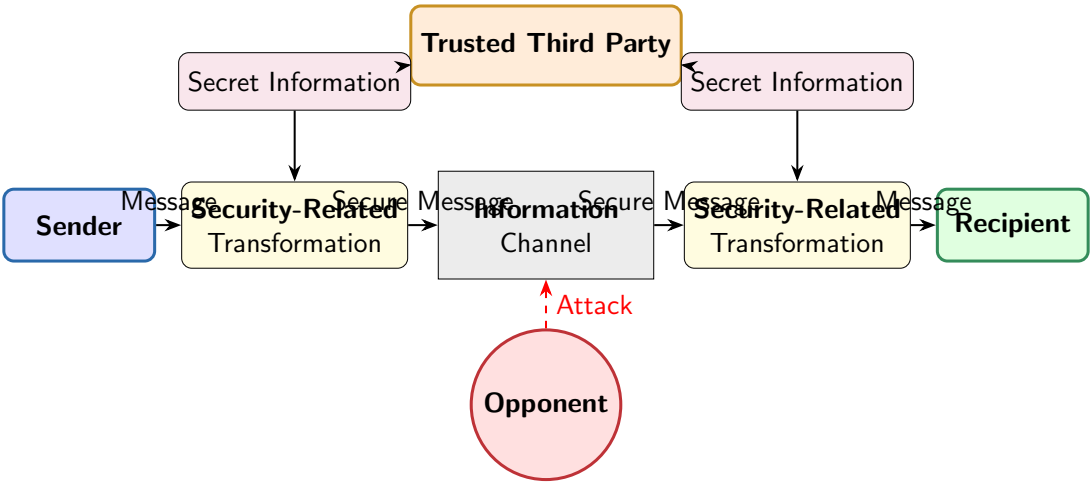
An opponent may attempt to:

- Read confidential information
- Modify transmitted data
- Impersonate the sender
- Replay an old message
- Disrupt the communication
- Deny that a message was sent or received

Security Objective

Communication must be protected against threats to confidentiality, integrity, authenticity, and availability.

General Model for Network Security



Elements of the Network Security Model

The general network security model contains:

1. Sender
2. Recipient
3. Message
4. Communication channel
5. Security-related transformation
6. Secret information
7. Opponent
8. Trusted third party
9. Security protocol

Sender and Recipient

Sender

The entity that generates and transmits the original message.

Recipient

The intended entity that receives and processes the message.

Examples

A user sending an email, a browser accessing a web server, or a bank customer performing an online transaction.

Information Channel

Definition

The information channel is the logical communication path established between the sender and recipient.

The channel may include:

- Local-area networks
- Wide-area networks
- Wireless communication
- Internet routers
- Cloud infrastructure
- Communication protocols such as TCP/IP

Security Concern

An opponent may observe, modify, insert, delete, or block messages passing through the channel.

Security-Related Transformation

Definition

A security-related transformation changes the original information to provide a security property.

Examples include:

- Encryption
- Message Authentication Code
- Cryptographic hash
- Digital signature
- Authentication token

Example: Encryption Transformation

$$\text{Plaintext} \xrightarrow[\text{Encryption Key}]{\text{Encryption Algorithm}} \text{Ciphertext}$$

$$\text{Ciphertext} \xrightarrow[\text{Decryption Key}]{\text{Decryption Algorithm}} \text{Plaintext}$$

- The sender encrypts the original message.
- The encrypted message travels through the network.
- The recipient decrypts the message.
- The opponent should not understand the intercepted ciphertext.

Example: Authentication Code

A code may be generated from the message contents:

$$T = f(K, M)$$

where:

- M is the message.
- K is the secret key.
- T is the authentication tag.

The recipient recomputes the tag and compares it with the received tag.

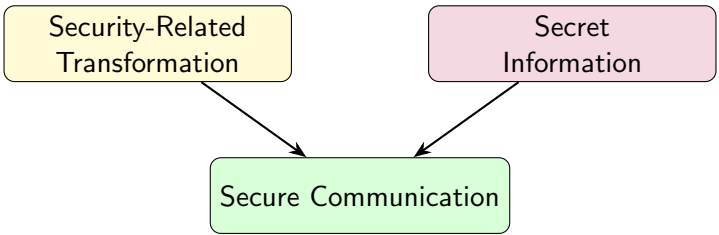
Purpose

The code can help verify message integrity and authenticate the sender.

Two Basic Components of Security

Most techniques for secure communication require two components:

1. A security-related transformation
2. Secret information used with the transformation



Secret Information

Definition

Secret information is information shared by authorized principals and, ideally, unknown to the opponent.

Examples include:

- Symmetric encryption keys
- Private cryptographic keys
- Passwords
- Session keys
- Authentication secrets
- One-time codes

Importance of Cryptographic Keys

The security of a cryptographic system often depends on the protection of its keys.

- Keys must be generated securely.
- Keys must be distributed only to authorized parties.
- Keys must be stored securely.
- Compromised keys must be revoked.
- Keys should be replaced periodically.
- Old keys may need to be destroyed securely.

Kerckhoffs's Principle

The security of a system should depend on the secrecy of the key, not on keeping the algorithm secret.

Role of an Opponent

An opponent is an unauthorized entity that attempts to defeat the security of communication. An opponent may:

- Intercept a message
- Read confidential data
- Modify information
- Insert false messages
- Replay a previous message
- Impersonate a legitimate entity
- Disrupt communication

Trusted Third Party

Definition

A trusted third party is an entity trusted by the communicating principals to assist in secure communication.

A trusted third party may:

- Distribute secret keys
- Verify identities
- Issue digital certificates
- Provide timestamps
- Arbitrate disputes
- Confirm message transmission

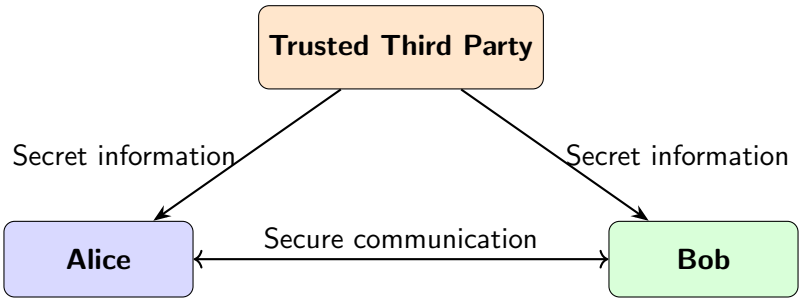
Examples of Trusted Third Parties

- Certificate Authority
- Key Distribution Centre
- Authentication Server
- Registration Authority
- Digital Notary
- Trusted Timestamping Authority

Example

A Certificate Authority verifies an organization's identity and issues a digital certificate containing its public key.

Trusted Third-Party Model



Four Basic Security Design Tasks

Designing a particular security service requires four basic tasks:

1. Design a secure transformation algorithm.
2. Generate the required secret information.
3. Distribute and share the secret information.
4. Specify a communication protocol.

Task 1: Design the Security Algorithm

The security algorithm should:

- Perform the required transformation correctly.
- Provide the intended security service.
- Resist known attacks.
- Be computationally efficient.
- Be practical for implementation.
- Prevent an opponent from defeating its purpose.

Examples

AES for encryption, SHA-3 for hashing, and RSA or ECDSA for digital signatures.

Task 2: Generate Secret Information

Secret information should be generated securely.
Important requirements include:

- High randomness
- Sufficient key length
- Unpredictability
- Resistance to brute-force guessing
- Secure random-number generation
- Protection from accidental disclosure

Task 3: Distribute Secret Information

The communicating parties must obtain the required secret information.
Possible methods include:

- Manual key distribution
- Key Distribution Centre
- Diffie–Hellman key exchange
- Public-key certificates
- Pre-shared keys
- Secure out-of-band communication

Challenge

A strong encryption algorithm is ineffective if its key is distributed insecurely.

Task 4: Specify the Security Protocol

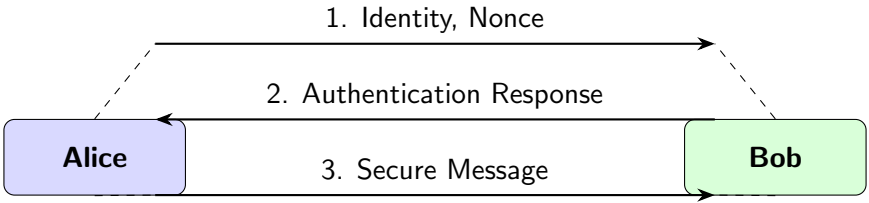
A protocol defines how the communicating entities use:

- Security algorithms
- Secret keys
- Message formats
- Nonces and timestamps
- Authentication values
- Sequence of communication steps

Examples

TLS, IPsec, Kerberos, SSH, and secure email protocols.

Security Protocol Illustration



Example: Secure Online Banking

In an online banking transaction:

- TLS provides secure communication.
- Encryption protects transaction details.
- Digital certificates authenticate the bank server.
- Session keys protect the current connection.
- Authentication verifies the customer.
- Message-integrity mechanisms prevent modification.
- Nonces and sequence numbers prevent replay.

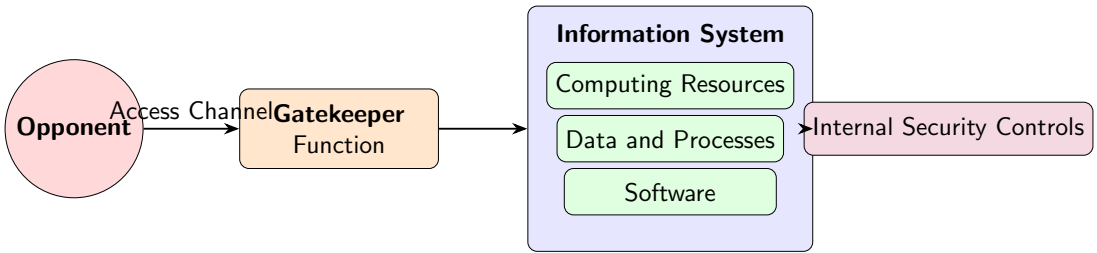
Limitations of the Communication Model

The general secure communication model mainly considers:

- Message protection
- Communication security
- Key sharing
- Authentication
- External opponents

However, some security problems involve unauthorized access to an information system itself.

Network Access Security Model



Purpose of the Network Access Model

The network access security model focuses on protecting an information system from unwanted access.
The opponent may be:

- An external hacker
- A disgruntled employee
- A cybercriminal
- Malicious software
- A virus
- A worm
- A compromised application

Human Opponents

Human intruders may include:

- Curious hackers
- Malicious insiders
- Disgruntled employees
- Organized cybercriminals
- Industrial spies
- State-sponsored attackers

Their objectives may include:

- Financial gain
- Information theft
- System damage
- Espionage
- Disruption of services

Software Opponents

Malicious software may be introduced through:

- Network downloads
- Email attachments
- Infected USB devices
- Compromised websites
- Vulnerable applications
- Software supply chains

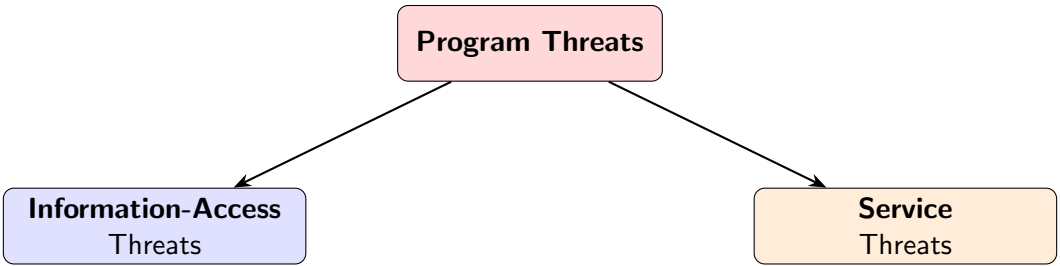
Examples

Viruses, worms, Trojan horses, spyware, ransomware, and malicious scripts.

Two Categories of Program Threats

Programs may present two broad categories of threats:

1. Information-access threats
2. Service threats



Information-Access Threats

Definition

Information-access threats intercept or modify data on behalf of users who are not authorized to access that information.

Examples include:

- Reading confidential files
- Stealing passwords
- Copying customer information
- Modifying database records
- Capturing credit-card numbers
- Unauthorized financial transfers

Service Threats

Definition

Service threats exploit weaknesses in computer services to prevent or inhibit legitimate use.

Examples include:

- Denial-of-service attacks
- Resource exhaustion
- Service crashes
- Ransomware
- Network flooding
- Destruction of system files

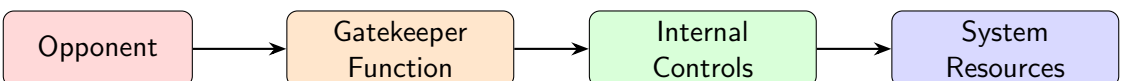
Information-Access vs Service Threats

Feature	**Information-Access Threat**	**Service Threat**
Objective	Access or modify data	Prevent legitimate use
Primary goals affected	Confidentiality and integrity	Availability
Example	Stealing customer records	Crashing a web server
Typical attacker action	Read or alter information	Disable or overload services

Two Lines of Defence

Security mechanisms for unwanted access fall into two broad categories:

1. Gatekeeper functions
2. Internal security controls



Gatekeeper Function

Definition

A gatekeeper function controls access at the boundary of an information system.

Gatekeeper mechanisms include:

- Username and password authentication
- Multi-factor authentication
- Firewalls
- Network access control
- Antivirus screening
- Email filtering
- Intrusion-prevention systems

Functions of a Gatekeeper

A gatekeeper should:

- Identify the requesting entity.
- Authenticate the entity.
- Verify access permissions.
- Reject unauthorized users.
- Detect malicious software.
- Filter suspicious network traffic.
- Record access attempts.

First Line of Defence

The gatekeeper attempts to prevent unwanted users and software from entering the information system.

Internal Security Controls

Definition

Internal security controls monitor system activity and stored information after access has been granted.

Examples include:

- Audit logging
- Intrusion detection
- File-integrity monitoring
- Behaviour analysis
- Malware detection
- Privilege monitoring
- Database activity monitoring

Purpose of Internal Controls

Internal controls are necessary because:

- A malicious user may bypass the gatekeeper.
- Authorized users may misuse their privileges.
- Malware may enter through trusted software.
- New vulnerabilities may remain undetected.
- Credentials may be stolen.
- Internal attacks may originate within the system.

Second Line of Defence

Internal controls detect and limit damage after an attacker or malicious program gains access.

Gatekeeper vs Internal Controls

Feature	Gatekeeper Function	Internal Controls
Location	System boundary	Inside the system
Primary purpose	Prevent unauthorized entry	Detect misuse after entry
Examples	Login, firewall, antivirus	Audit logs, IDS, monitoring
Security role	First line of defence	Second line of defence

Example: University ERP

Consider a university ERP system:

- Password and OTP authenticate faculty members.
- Role-based access control restricts grade modification.
- TLS encrypts communication.
- Audit logs record every grade update.
- File-integrity monitoring detects unauthorized changes.
- Intrusion-detection systems identify suspicious activity.
- Backups support recovery from system failure.

Example: Hospital Information System

- Doctors and nurses are authenticated.
- Access rights depend on professional roles.
- Patient data is encrypted.
- Every access to patient records is logged.
- Changes to medical data are monitored.
- Malware scanning protects medical systems.
- Backup servers provide service availability.

Critical Requirement

Unauthorized access or modification may directly endanger patient safety.

Secure Communication vs Access Security

Feature	Network Security Model	Network Access Model
Main concern	Protect transmitted messages	Protect information systems
Primary entities	Sender and recipient	User, software, and system
Main controls	Encryption, keys, protocols	Gatekeeper and internal controls
Typical threat	Interception or modification	Unauthorized system access

Security Design Checklist

When designing a secure network application, ask:

1. What information requires protection?
2. Who are the communicating entities?
3. What threats and opponents exist?
4. Which security service is required?
5. Which transformation will provide the service?
6. What secret information is required?
7. How will keys be generated and distributed?
8. Is a trusted third party required?
9. Which protocol will coordinate the communication?
10. What access controls and monitoring are necessary?

Class Activity

For an online examination system, identify:

1. The sender and recipient
2. The sensitive message
3. The possible opponent
4. A suitable security transformation
5. The secret information required
6. A possible trusted third party
7. The gatekeeper function
8. Suitable internal security controls

Possible Activity Answer

For an online examination system:

- **Sender:** Student device
- **Recipient:** Examination server
- **Message:** Answers and authentication data
- **Opponent:** Hacker or impersonating student
- **Transformation:** Encryption and integrity protection
- **Secret information:** Session key
- **Trusted party:** Certificate Authority
- **Gatekeeper:** Login, MFA, and access control
- **Internal controls:** Logs and behaviour monitoring

Quick Quiz

1. What are the two basic components of a security technique?
2. What is a security-related transformation?
3. Give two examples of secret information.
4. What is the role of a trusted third party?
5. State the four basic tasks in designing a security service.
6. What is an information-access threat?
7. What is a service threat?
8. What is the difference between a gatekeeper and an internal control?

References

- William Stallings, *Cryptography and Network Security: Principles and Practice*.
- William Stallings and Lawrie Brown, *Computer Security: Principles and Practice*.
- ITU-T Recommendation X.800, *Security Architecture for Open Systems Interconnection*.
- NIST, *Computer Security and Cryptographic Standards*.

Thank You

Questions and Discussion